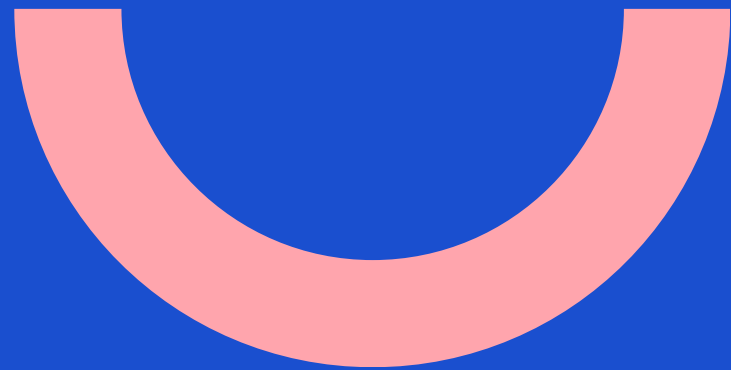


Incident Response Playbook

Business Email Compromise

Responding to Data Ex-filtration Incidents





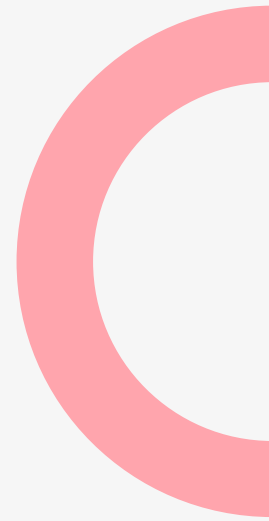
Incident Detection

Common indicators of BEC:

- Unusual email activity
- Unexpected password changes
- Suspicious login attempts
- Data access anomalies
- Monitoring tools and techniques

Incident Detection

Indicators of Compromise (IoCs)



01 UNUSUAL EMAIL ACTIVITY

- Unexpected out-of-office replies
- Emails sent at odd hours
- Increase in email volume to external domains

02 ACCOUNT ANOMALIES

- Failed login attempts from unrecognized IP addresses
- Password resets not initiated by the user
- MFA challenges from unfamiliar locations

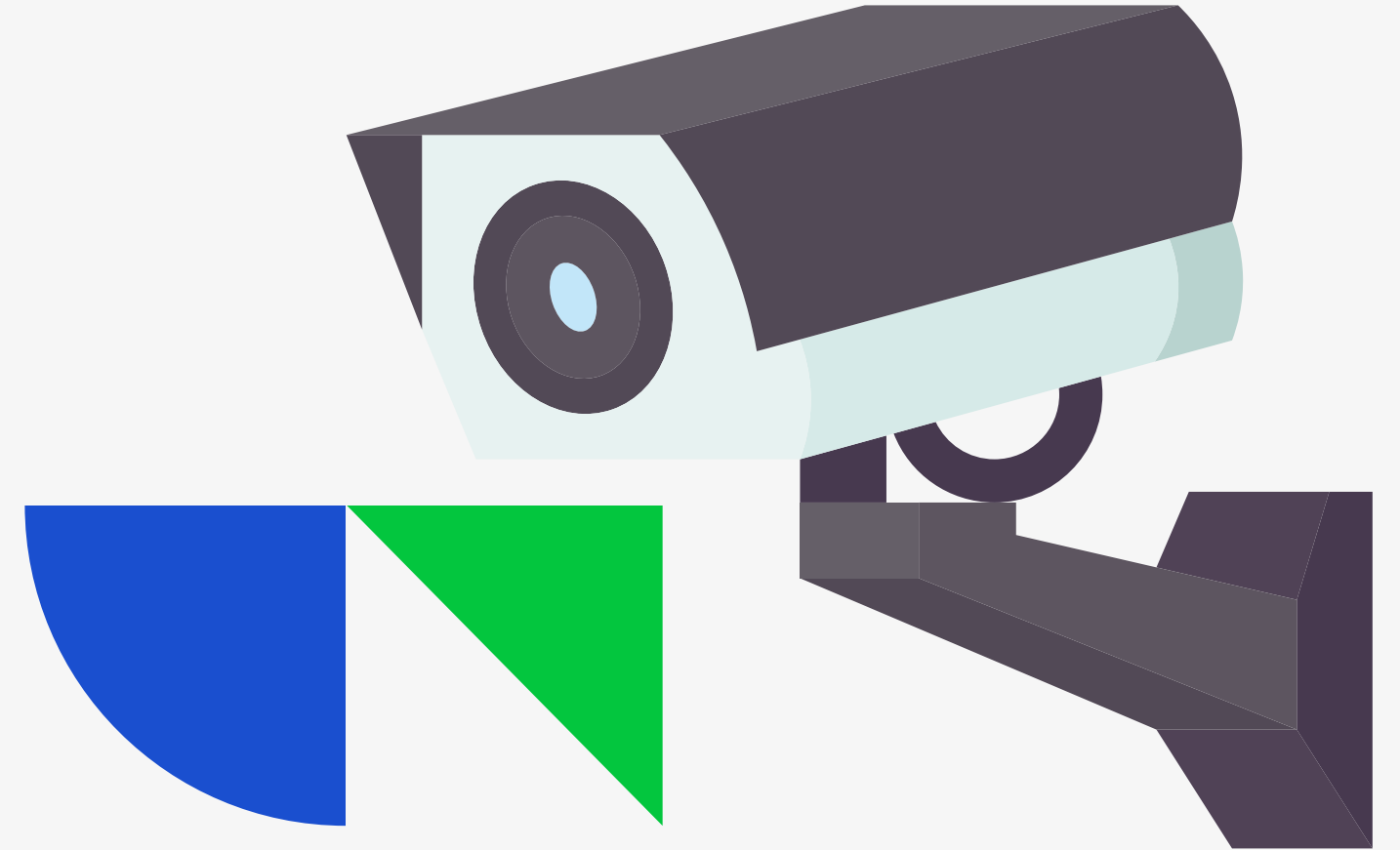
03 DATA ACCESS PATTERNS

- Large data transfers to external email addresses
- Accessing sensitive files outside business hours
- Unusual database queries or bulk data exports



Incident Detection

Monitoring Tools



01 EMAIL SECURITY GATEWAY

Configure alerts for

- Emails with similar display names but different domains
- Sudden increase in email forwarding rules

02 SIEM TOOL

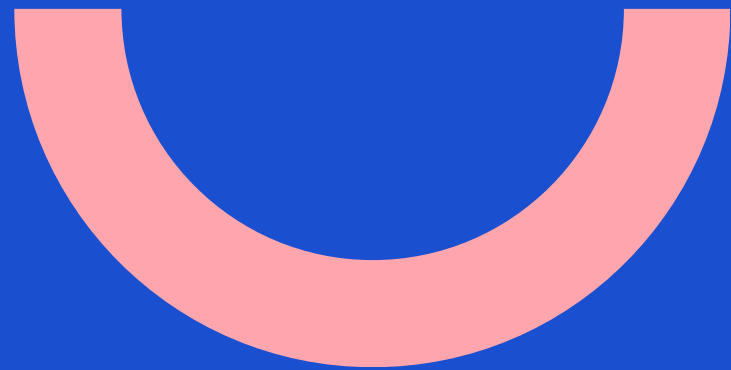
Create correlation rules to detect:

- Multiple failed logins followed by a successful login from a new IP
- Unusual access to systems during non business hours

03 DATA LOSS PREVENTION TOOL

Set up policies to flag:

- Emails containing specific keywords (e.g., "wire transfer", "urgent payment")



Initial Response

- Activate the Incident Response Team
- Establish a secure communication channel
- Document all actions and findings
- Perform initial assessment:
- Scope of compromise
- Data potentially affected
- Systems involved

Initial Response



Incident Response Team Activation

- Incident Commander: Call the emergency response number
- Use the secure messaging app "SecureComm" to notify team members
- Convene in the designated war room
- Implement a dedicated email address: security-alert@company.com
- Create a web-based reporting form accessible from the company intranet
- Establish a 24/7 security hotline

Secure Communication Channel

- Use encrypted chat platform "SecureChat" for all incident-related communications
- Invite only essential personnel, use role-based access control.

Initial Assessment Checklist

- Compromised email accounts: []
Identify affected user(s) [] List all email addresses involved [] Determine time of initial compromise
- Potential data exposure: [] Review email forwarding rules [] Check for bulk downloads from cloud storage []
Analyze recent large file transfers
- System access: [] List all systems accessed by compromised account(s) []
Identify any elevated privileges used [] Check for newly created accounts or changed permissions



Incident Containment



- Isolate affected systems
- Block malicious IP addresses and email addresses
- Disable compromised accounts
- Implement additional access controls
- Preserve evidence for forensic analysis

Initial Containment



NETWORK SEGREGATION:

- MAINTAIN LIST OF QUARANTINED IP ADDRESSES
- COMMAND TO ISOLATE AFFECTED SUBNET: `FIREWALL-CMD --ZONE=ISOLATED --CHANGE-INTERFACE=ETH1`

ACCOUNT SUSPENSION :

- ACTIVE DIRECTORY: `DISABLE-ADACCOUNT -IDENTITY "USERNAME"`
- GOOGLE WORKSPACE: `GAM UPDATE USER USERNAME SUSPENDED ON`
- OFFICE 365: `SET-MSOLUSER -USERPRINCIPALNAME "USERNAME@DOMAIN.COM" -BLOCKCREDENTIAL $TRUE`

EMAIL QUARANTINE :

- `NEW-TRANSPORTRULE -NAME "QUARANTINE COMPROMISED ACCOUNT" -SENDERADDRESSCONTAINS "COMPROMISED@COMPANY.COM" -SETSCL 9`

FIREWALL RULE TO BLOCK MALICIOUS IPS :

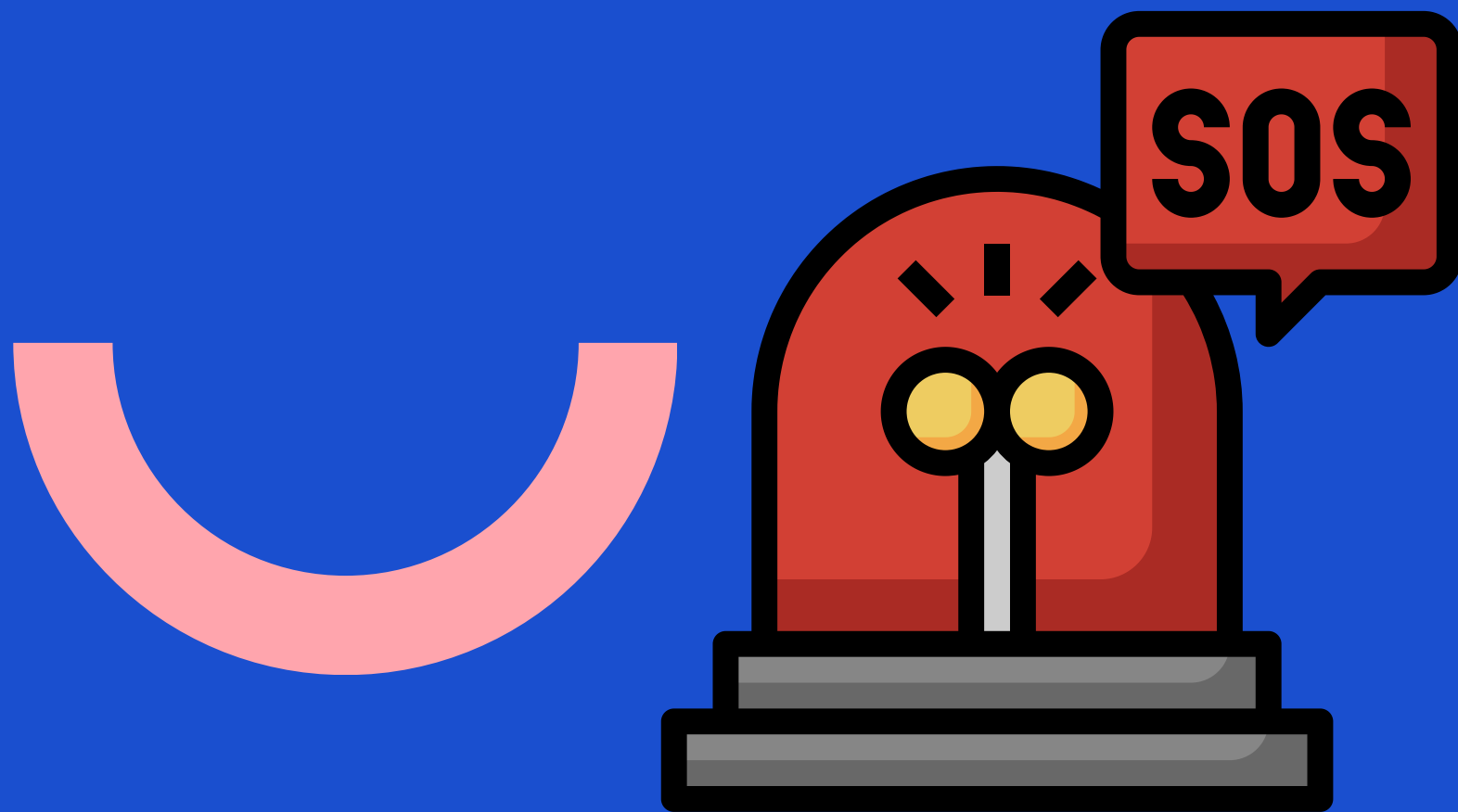
- `IPTABLES -A INPUT -S 192.168.1.100 -J DROP`
- `IPTABLES -A OUTPUT -D 192.168.1.100 -J DROP`

UPDATE DNS BLACKLISTS:

- ADD MALICIOUS DOMAINS TO INTERNAL DNS SINKHOLE
- SUBSCRIBE TO REPUTABLE THREAT INTELLIGENCE FEEDS



Incident Eradiation



- Remove malware and unauthorized access tools
- Close security gaps:
- Patch vulnerabilities
- Update firewall rules
- Strengthen email filters
- Reset all passwords for affected and related accounts
- Implement additional security measures (e.g., MFA)

Initial Eradication



MALWARE REMOVAL

- RUN FULL SYSTEM SCAN: CLAMSCAN -R --BELL -I /
- REMOVE IDENTIFIED THREATS: MALWAREBYTES_CLI.EXE -REMOVE -ALL
- CHECK FOR AND REMOVE UNAUTHORIZED SCHEDULED TASKS:
 - SCHEDTASKS /QUERY /FO LIST /V | FINDSTR /I "TASKNAME AUTHOR"
 - SCHEDTASKS /DELETE /TN "SUSPICIOUSTASK" /F

OTHER SECURITY MEASURES

- FORCE PASSWORD RESET FOR ALL USERS: GET-ADUSER -FILTER * -SEARCHBASE "OU=USERS,DC=COMPANY,DC=COM" | SET-ADUSER -CHANGEPASSWORDATLOGON \$TRUE
- UPDATE FIREWALL RULES:
 - UFW DEFAULT DENY INCOMING
 - UFW ALLOW FROM 192.168.1.0/24 TO ANY PORT 22
 - UFW ENABLE
- ENABLE MFA FOR ALL ACCOUNTS:
 - GET-MSOLUSER -ALL | SET-MSOLUSER -STRONGAUTHENTICATIONREQUIREMENTS @("ENABLED")

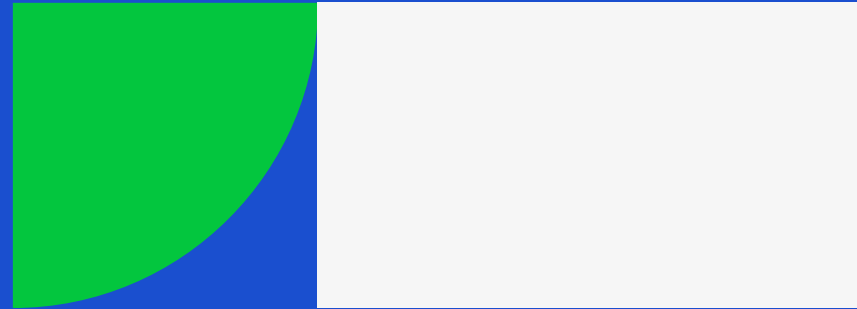
Incident Eradication

ENHANCE EMAIL FILTERS (POSTFIX):

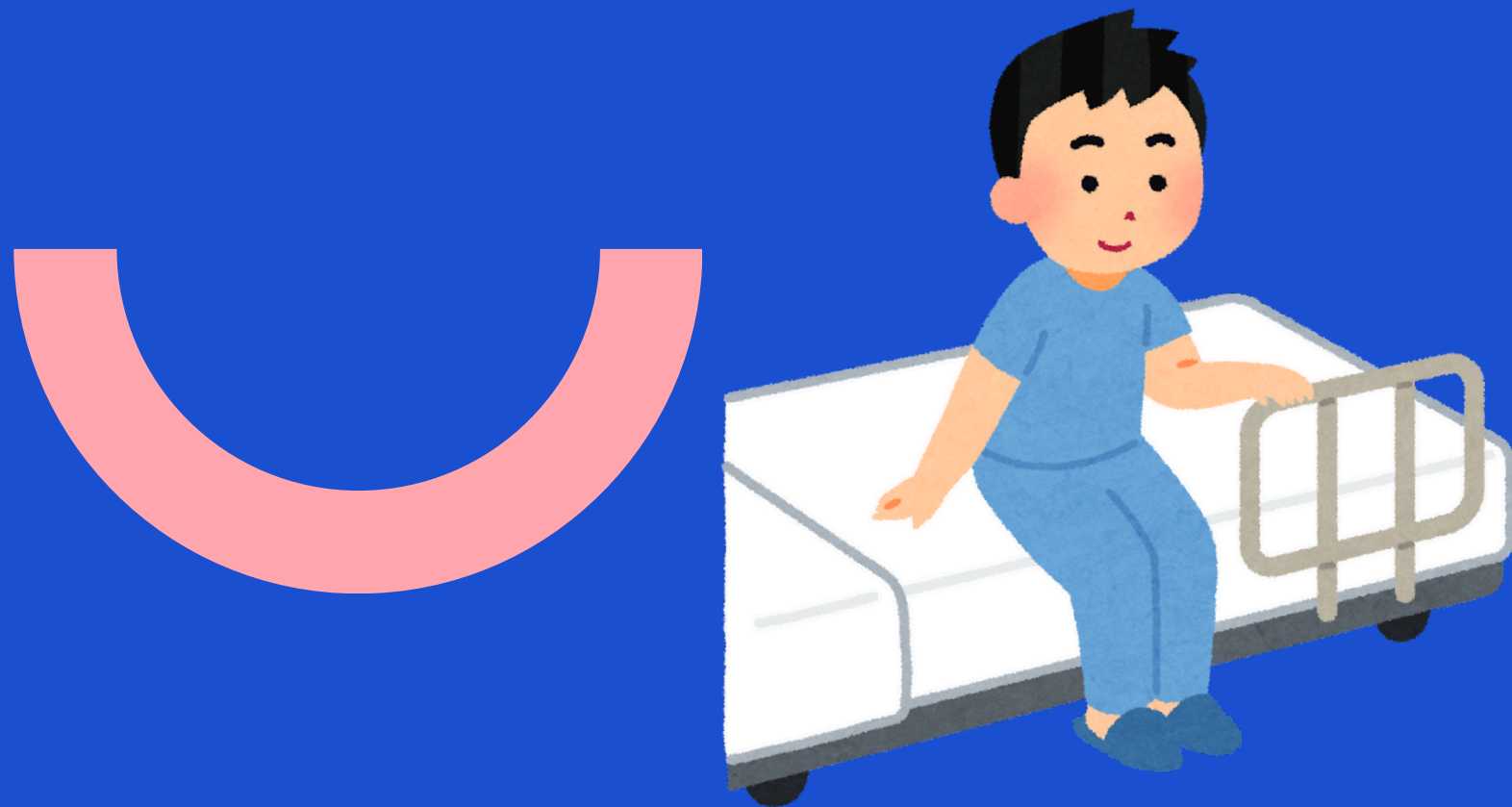
- # /ETC/POSTFIX/MAIN.CF
- SMTPD_SENDER_RESTRICTIONS =
 - REJECT_NON_FQDN_SENDER,
 - REJECT_UNKNOWN_SENDER_DOMAIN,
 - REJECT_AUTHENTICATED_SENDER_LOGIN_MISMATCH,
 - PERMIT_SASL_AUTHENTICATED,
 - REJECT_UNAUTH_DESTINATION

OTHER SECURITY MEASURES

- **IMPLEMENT DMARC POLICY:**
 - _DMARC.COMPANY.COM. IN TXT "V=DMARC1; P=REJECT; RUA=MAILTO:DMARC-REPORTS@COMPANY.COM"
- **ENABLE DETAILED LOGGING:**
 - AUDITCTL -W /ETC/PASSWD -P WA -K IDENTITY
 - AUDITCTL -W /ETC/GROUP -P WA -K IDENTITY



System Recovery



- Restore systems from clean backups
- Verify data integrity
- Implement enhanced monitoring
- Gradually restore services with continuous monitoring
- Conduct security scans before full restoration

System Recovery

STEP 1: RESTORE FROM CLEAN BACKUPS



- **IDENTIFY LAST KNOWN CLEAN BACKUP**

- # LIST AVAILABLE BACKUPS
- RESTIC SNAPSHOTS --REPO /PATH/TO/BACKUP/REPO

- **RESTORE CRITICAL SYSTEMS:**

- # RESTORE ENTIRE SYSTEM
- RESTIC RESTORE LATEST --TARGET /MNT/RESTORE
- # RESTORE SPECIFIC DIRECTORIES
- RESTIC RESTORE LATEST --TARGET /MNT/RESTORE --INCLUDE /VAR/WWW --INCLUDE /ETC

- **VERIFY RESTORED DATA INTEGRITY:**

- # COMPARE RESTORED FILES WITH CURRENT FILES
- DIFF -R /MNT/RESTORE/VAR/WWW /VAR/WWW

System Recovery

STEP 2: IMPLEMENT ENHANCED MONITORING



• CONFIGURE ENHANCED LOGGING:

- # EDIT RSYSLOG CONFIGURATION
- VIM /ETC/RSYSLOG.CONF
- # ADD THE FOLLOWING LINES TO ENABLE MORE DETAILED LOGGING
- AUTH,AUTHPRIV.* /VAR/LOG/AUTH.LOG
- *.*;AUTH,AUTHPRIV.NONE -/VAR/LOG/SYSLOG
- DAEMON.* -/VAR/LOG/DAEMON.LOG
- KERN.* -/VAR/LOG/KERN.LOG
- MAIL.* -/VAR/LOG/MAIL.LOG
- USER.* -/VAR/LOG/USER.LOG

• IMPLEMENT NETWORK TRAFFIC ANALYSIS:

- # INSTALL AND CONFIGURE ZEEK (FORMERLY BRO)
- APT-GET INSTALL ZEEK
- # EDIT ZEEK CONFIGURATION
- VIM /ETC/ZEEK/NETWORKS.CFG
- # ADD YOUR NETWORK RANGE
- 10.0.0.0/8 PRIVATE IP SPACE
- 172.16.0.0/12 PRIVATE IP SPACE
- 192.168.0.0/16 PRIVATE IP SPACE



Post- Incident Analysis



- Conduct a comprehensive forensic analysis
- Determine the root cause
- Assess the full extent of data exfiltration
- Identify and document lessons learned
- Update incident response procedures based on findings

Post Incident Analysis

- **EMAIL ANALYSIS**

- # USING PYTHON TO PARSE EMAIL HEADERS
- IMPORT EMAIL
- FROM EMAIL IMPORT POLICY
- WITH OPEN('SUSPICIOUS_EMAIL.EML', 'RB') AS F:
- MSG = EMAIL.MESSAGE_FROM_BYTES(F.READ(), POLICY=POLICY.DEFAULT)
- PRINT("FROM:", MSG['FROM'])
- PRINT("DATE:", MSG['DATE'])
- PRINT("SUBJECT:", MSG['SUBJECT'])
- PRINT("RECEIVED PATH:")
- FOR I, HEADER IN ENUMERATE(MSG.GET_ALL('RECEIVED')):
- PRINT(F"{I + 1}: {HEADER}")

- **NETWORK TRAFFIC ANALYSIS:**

- # USING WIRESHARK CLI (TSHARK)
- TSHARK -R CAPTURE.PCAP -Y "HTTP.REQUEST.METHOD == GET" -T FIELDS -E HTTP.HOST -E HTTP.REQUEST.URI



Thank You For Reading!

Follow us for more such creative infosec contents

LINKEDIN

[MINISTRYOFSECURITY.CO](#)

WEBSITE

[WWW.MINISTRYOFSECURITY.CO](#)